

POLÍTICA DE SEGURIDAD Y PREVENCIÓN DE FRAUDES

NexaLend

Versión: 1.0

Fecha de entrada en vigor: 16 de julio de 2026

Clasificación: Documento Público

Propietario del documento: Área de Seguridad de la Información, Riesgos y Prevención de Fraudes – NexaLend

ÍNDICE

1. Introducción
2. Objetivos
3. Alcance
4. Definiciones
5. Principios de Seguridad
6. Modelo de Gestión de Riesgos
7. Gobierno de la Seguridad
8. Gestión de Identidades y Accesos
9. Autenticación de Usuarios
10. Seguridad de Credenciales
11. Seguridad de Dispositivos
12. Seguridad de la Infraestructura Tecnológica
13. Protección de Redes
14. Seguridad de Aplicaciones
15. Seguridad de APIs
16. Cifrado y Protección de Datos
17. Monitoreo de Transacciones
18. Prevención de Fraude
19. Gestión de Alertas
20. Bloqueos Preventivos
21. Gestión de Incidentes
22. Continuidad del Negocio
23. Seguridad para Comercios
24. Seguridad para Usuarios
25. Responsabilidades de los Empleados
26. Capacitación y Concientización
27. Auditorías y Controles

- 28. Cumplimiento Normativo
 - 29. Sanciones por Incumplimiento
 - 30. Mejora Continua
 - 31. Contacto
 - 32. Glosario
-

1. INTRODUCCIÓN

La confianza es el activo más importante de NexaLend. Como plataforma financiera digital, la seguridad de la información, la protección de los fondos y la prevención del fraude constituyen pilares fundamentales para garantizar un servicio confiable, resiliente y transparente.

Esta Política de Seguridad y Prevención de Fraudes establece los principios, controles, procedimientos y responsabilidades que rigen la protección de los activos digitales, la infraestructura tecnológica, la información de los usuarios y las operaciones financieras realizadas a través de NexaLend.

El documento es aplicable a empleados, usuarios, comercios, proveedores tecnológicos y cualquier tercero que interactúe con los sistemas de NexaLend.

2. OBJETIVOS

Los principales objetivos de esta política son:

- Proteger la información de usuarios y comercios.
 - Garantizar la confidencialidad, integridad y disponibilidad de los datos.
 - Reducir el riesgo de fraude financiero.
 - Detectar actividades sospechosas de manera temprana.
 - Proteger los activos tecnológicos de NexaLend.
 - Cumplir con las obligaciones regulatorias.
 - Establecer procedimientos claros para responder a incidentes de seguridad.
 - Promover una cultura de seguridad en toda la organización.
-

3. ALCANCE

Esta política aplica a:

- Aplicaciones móviles de NexaLend.
 - Sitio web institucional.
 - Plataforma de pagos.
 - APIs públicas y privadas.
 - Billeteras digitales.
 - Infraestructura en la nube.
 - Centros de procesamiento de datos.
 - Sistemas administrativos.
 - Sistemas de atención al cliente.
 - Equipos corporativos.
 - Personal interno.
 - Comercios adheridos.
 - Proveedores tecnológicos.
 - Integraciones con terceros.
-

4. DEFINICIONES

Activo de información: Todo elemento que posee valor para NexaLend, incluyendo datos, software, hardware y documentación.

Fraude: Acción destinada a obtener un beneficio indebido mediante engaño o manipulación.

Incidente de seguridad: Evento que afecta o puede afectar la confidencialidad, integridad o disponibilidad de la información.

Autenticación Multifactor (MFA): Método que requiere dos o más factores independientes para validar la identidad de un usuario.

Tokenización: Sustitución de información sensible por identificadores seguros.

Phishing: Técnica utilizada para obtener información confidencial mediante suplantación de identidad.

Ingeniería social: Manipulación psicológica para inducir a una persona a revelar información o realizar acciones que comprometan la seguridad.

5. PRINCIPIOS DE SEGURIDAD

La estrategia de seguridad de NexaLend se basa en los siguientes principios:

- Seguridad desde el diseño (Security by Design).

- Privacidad desde el diseño (Privacy by Design).
 - Mínimo privilegio.
 - Defensa en profundidad.
 - Segmentación de accesos.
 - Monitoreo continuo.
 - Gestión basada en riesgos.
 - Mejora continua.
 - Trazabilidad de eventos.
 - Respuesta rápida ante incidentes.
-

6. MODELO DE GESTIÓN DE RIESGOS

NexaLend adopta un enfoque preventivo para identificar, evaluar y tratar los riesgos asociados a la operación de la plataforma.

Las etapas incluyen:

1. Identificación de amenazas.
2. Identificación de vulnerabilidades.
3. Evaluación de impacto.
4. Evaluación de probabilidad.
5. Definición del nivel de riesgo.
6. Implementación de controles.
7. Monitoreo continuo.
8. Revisión periódica.

Los riesgos son reevaluados regularmente o cuando se producen cambios significativos en la infraestructura o en el marco regulatorio.

7. GOBIERNO DE LA SEGURIDAD

La gestión de la seguridad es responsabilidad compartida entre las distintas áreas de NexaLend.

Las principales funciones incluyen:

- Definir políticas y estándares.
- Aprobar controles de seguridad.
- Supervisar la gestión de riesgos.
- Coordinar auditorías.
- Gestionar incidentes.
- Promover la capacitación del personal.

El Comité de Seguridad revisa periódicamente el desempeño de los controles y propone mejoras.

8. GESTIÓN DE IDENTIDADES Y ACCESOS

El acceso a los sistemas de NexaLend se basa en el principio de mínimo privilegio.

Las medidas incluyen:

- Cuentas individuales.
 - Prohibición de cuentas compartidas.
 - Asignación de roles.
 - Revisión periódica de permisos.
 - Revocación inmediata de accesos al finalizar una relación laboral o contractual.
 - Registro de todas las actividades relevantes.
-

9. AUTENTICACIÓN DE USUARIOS

Para proteger las cuentas, NexaLend implementa mecanismos como:

- Contraseñas robustas.
- Autenticación multifactor (MFA).
- Verificación biométrica cuando el dispositivo lo permita.
- Validación mediante códigos de un solo uso (OTP).
- Confirmación de operaciones sensibles.

En determinadas circunstancias podrán requerirse verificaciones adicionales antes de autorizar una operación.

10. SEGURIDAD DE CREDENCIALES

Los usuarios deben:

- Crear contraseñas únicas.
- No reutilizar contraseñas de otros servicios.
- No compartir códigos de verificación.

- Cambiar la contraseña cuando exista sospecha de compromiso.
- Mantener actualizado su correo electrónico y número de teléfono.

NexaLend nunca solicitará contraseñas, PIN o códigos OTP por teléfono, correo electrónico o mensajería.

11. SEGURIDAD DE DISPOSITIVOS

Los usuarios son responsables de proteger los dispositivos desde los cuales acceden a la plataforma.

Se recomienda:

- Mantener el sistema operativo actualizado.
 - Instalar aplicaciones únicamente desde tiendas oficiales.
 - Utilizar bloqueo de pantalla.
 - Activar el cifrado del dispositivo cuando esté disponible.
 - Evitar redes Wi-Fi públicas para operaciones sensibles.
 - Reportar inmediatamente la pérdida o robo del dispositivo.
-

12. SEGURIDAD DE LA INFRAESTRUCTURA TECNOLÓGICA

La infraestructura de NexaLend incorpora controles como:

- Segmentación de redes.
 - Firewalls.
 - Balanceadores de carga.
 - Sistemas de detección y prevención de intrusiones.
 - Protección contra ataques de denegación de servicio (DDoS).
 - Monitoreo de disponibilidad.
 - Gestión segura de configuraciones.
 - Copias de seguridad periódicas.
-

13. PROTECCIÓN DE REDES

Las comunicaciones entre usuarios y la plataforma se realizan mediante protocolos cifrados.

Se implementan controles para:

- Filtrar tráfico malicioso.
 - Detectar conexiones anómalas.
 - Restringir accesos no autorizados.
 - Supervisar el comportamiento de la red.
-

14. SEGURIDAD DE APLICACIONES

Durante el desarrollo de software se aplican prácticas de desarrollo seguro, incluyendo:

- Revisión de código.
 - Análisis de vulnerabilidades.
 - Pruebas de penetración.
 - Validación de entradas.
 - Gestión segura de sesiones.
 - Protección frente a ataques comunes como inyección de código o cross-site scripting (XSS).
-

15. SEGURIDAD DE APIs

Las APIs de NexaLend utilizan mecanismos de autenticación y autorización para proteger el intercambio de información.

Entre los controles implementados se incluyen:

- Tokens de acceso.
 - Límites de solicitudes (rate limiting).
 - Registro de actividad.
 - Validación de origen.
 - Versionado seguro.
 - Revocación de credenciales comprometidas.
-

16. CIFRADO Y PROTECCIÓN DE DATOS

La información sensible se protege mediante técnicas de cifrado tanto en tránsito como en reposo.

Además, NexaLend utiliza:

- Tokenización de datos sensibles.
 - Hash seguro para contraseñas.
 - Gestión centralizada de claves criptográficas.
 - Políticas de rotación de claves.
-

17. MONITOREO DE TRANSACCIONES

Las operaciones son analizadas en tiempo real para identificar comportamientos inusuales.

Los sistemas consideran factores como:

- Frecuencia de operaciones.
- Montos.
- Ubicación geográfica.
- Dispositivo utilizado.
- Horarios de actividad.
- Historial del usuario.
- Cambios repentinos en el patrón de uso.

Cuando se detecta un comportamiento atípico, la operación puede ser retenida para revisión.

18. PREVENCIÓN DE FRAUDE

NexaLend emplea una combinación de controles automáticos y revisiones manuales para prevenir distintos tipos de fraude, entre ellos:

- Robo de identidad.
- Phishing.
- Ingeniería social.
- Fraude con tarjetas.
- Fraude por cuentas comprometidas.
- Creación masiva de cuentas falsas.
- Abuso de promociones.
- Manipulación de dispositivos.
- Lavado de dinero.
- Financiamiento de actividades ilícitas.

Los modelos de detección son revisados y ajustados periódicamente para responder a nuevas amenazas.

19. GESTIÓN DE ALERTAS

Las alertas generadas por los sistemas de monitoreo son clasificadas según su nivel de criticidad.

Dependiendo del riesgo detectado, podrán ejecutarse acciones como:

- Solicitar autenticación adicional.
- Limitar temporalmente determinadas funciones.
- Requerir documentación complementaria.
- Derivar el caso al equipo especializado.
- Notificar al usuario sobre la actividad detectada.

20. BLOQUEOS PREVENTIVOS

Con el objetivo de proteger los fondos y la información, NexaLend podrá bloquear temporalmente una cuenta cuando existan indicios razonables de:

- Accesos no autorizados.
- Operaciones incompatibles con el perfil del usuario.
- Intentos reiterados de autenticación fallida.
- Posible compromiso de credenciales.
- Requerimientos de autoridades competentes.

El bloqueo preventivo permanecerá vigente hasta completar las verificaciones correspondientes.

21. GESTIÓN DE INCIDENTES

Ante un incidente de seguridad, NexaLend seguirá un proceso estructurado que comprende:

1. Detección.
2. Registro.
3. Clasificación.
4. Contención.
5. Investigación.
6. Erradicación de la causa.
7. Recuperación del servicio.

8. Comunicación a las partes afectadas cuando corresponda.
9. Elaboración de un informe final.
10. Implementación de medidas correctivas.

Todos los incidentes relevantes quedan documentados para facilitar auditorías y acciones de mejora.

22. CONTINUIDAD DEL NEGOCIO

NexaLend mantiene planes de continuidad y recuperación ante desastres para minimizar el impacto de interrupciones operativas.

Estos planes contemplan:

- Copias de seguridad periódicas.
 - Redundancia de servicios críticos.
 - Procedimientos de restauración.
 - Pruebas regulares de recuperación.
 - Definición de tiempos objetivos de recuperación.
-

23. SEGURIDAD PARA COMERCIOS

Los comercios adheridos deberán:

- Proteger sus credenciales de acceso.
 - Utilizar dispositivos autorizados.
 - Verificar la identidad de sus operadores.
 - Reportar actividades sospechosas.
 - Mantener actualizado el software de los lectores de tarjetas.
 - Cumplir las políticas de seguridad de NexaLend.
-

24. SEGURIDAD PARA USUARIOS

Se recomienda a los usuarios:

- Activar la autenticación multifactor.
- Revisar periódicamente el historial de operaciones.
- No compartir códigos de verificación.

- Desconfiar de mensajes no solicitados.
 - Acceder únicamente desde la aplicación oficial o el sitio web autorizado.
 - Informar inmediatamente cualquier actividad sospechosa.
-

25. RESPONSABILIDADES DE LOS EMPLEADOS

Todos los colaboradores de NexaLend deben:

- Cumplir las políticas internas de seguridad.
- Proteger la información confidencial.
- Reportar incidentes de forma inmediata.
- Participar en programas de capacitación.
- Utilizar únicamente herramientas autorizadas.
- Respetar los niveles de acceso asignados.

El incumplimiento podrá dar lugar a medidas disciplinarias.

26. CAPACITACIÓN Y CONCIENTIZACIÓN

NexaLend desarrolla programas periódicos de formación para empleados y campañas informativas dirigidas a usuarios y comercios.

Los contenidos incluyen:

- Reconocimiento de intentos de phishing.
 - Buenas prácticas de seguridad.
 - Protección de credenciales.
 - Gestión de incidentes.
 - Uso seguro de dispositivos.
 - Prevención de ingeniería social.
-

27. AUDITORÍAS Y CONTROLES

Se realizan auditorías internas y externas para verificar la eficacia de los controles implementados.

Las revisiones pueden abarcar:

- Infraestructura tecnológica.
- Procesos operativos.
- Gestión de accesos.
- Seguridad de aplicaciones.
- Protección de datos.
- Cumplimiento normativo.

Los resultados generan planes de acción y seguimiento.

28. CUMPLIMIENTO NORMATIVO

NexaLend procura que sus procesos de seguridad sean compatibles con las mejores prácticas internacionales y con la normativa aplicable en materia de:

- Protección de datos personales.
 - Servicios financieros.
 - Prevención del lavado de dinero.
 - Seguridad de la información.
 - Gestión de riesgos.
 - Protección al consumidor.
-

29. SANCIONES POR INCUMPLIMIENTO

El incumplimiento de esta política podrá dar lugar, según la gravedad del caso, a:

- Advertencias.
 - Suspensión de accesos.
 - Bloqueo temporal de cuentas.
 - Terminación de relaciones contractuales.
 - Acciones legales.
 - Notificación a autoridades competentes cuando corresponda.
-

30. MEJORA CONTINUA

La presente política será revisada periódicamente para incorporar:

- Nuevas amenazas detectadas.
 - Cambios regulatorios.
 - Avances tecnológicos.
 - Resultados de auditorías.
 - Lecciones aprendidas de incidentes.
 - Recomendaciones derivadas de evaluaciones de riesgo.
-

31. CONTACTO

Área de Seguridad de la Información y Prevención de Fraudes – NexaLend

Correo electrónico: seguridad@NexaLend.com

Canales de reporte:

- Centro de Ayuda de la aplicación.
 - Portal web de soporte.
 - Chat de atención.
 - Formulario de reporte de incidentes.
-

32. GLOSARIO

API: Interfaz que permite la comunicación entre aplicaciones.

Autenticación Multifactor (MFA): Método de autenticación basado en dos o más factores independientes.

DDoS (Distributed Denial of Service): Ataque destinado a saturar un servicio mediante múltiples solicitudes simultáneas.

Ingeniería Social: Técnicas de manipulación utilizadas para obtener información confidencial de una persona.

KYC (Know Your Customer): Procedimiento de identificación y verificación de clientes.

OTP (One-Time Password): Código de uso único empleado para confirmar operaciones o accesos.

Phishing: Intento de obtener información confidencial mediante la suplantación de una entidad legítima.

Tokenización: Sustitución de datos sensibles por identificadores únicos que reducen el riesgo de exposición.

XSS (Cross-Site Scripting): Vulnerabilidad que permite la ejecución de código malicioso en aplicaciones web.

ANEXO A – BUENAS PRÁCTICAS DE SEGURIDAD PARA LOS USUARIOS

- Nunca compartas tu contraseña, PIN o códigos OTP.
 - Activa la autenticación multifactor siempre que esté disponible.
 - Revisa con frecuencia el historial de movimientos de tu cuenta.
 - Mantén actualizados el sistema operativo y la aplicación de NexaLend.
 - Descarga la aplicación únicamente desde tiendas oficiales.
 - Evita conectarte a redes Wi-Fi públicas para realizar operaciones financieras.
 - Desconfía de enlaces recibidos por correo electrónico, SMS o mensajería instantánea que soliciten datos personales o credenciales.
 - Verifica cuidadosamente el destinatario antes de confirmar una transferencia o un pago.
 - Reporta inmediatamente cualquier actividad sospechosa al equipo de soporte.
-

ANEXO B – INDICADORES COMUNES DE FRAUDE

Las siguientes situaciones pueden indicar un posible intento de fraude:

- Solicitudes urgentes para compartir códigos de verificación.
- Correos electrónicos que imitan la imagen de NexaLend con errores ortográficos o direcciones sospechosas.
- Llamadas telefónicas que solicitan contraseñas o PIN.
- Cambios inesperados en los datos de contacto asociados a una cuenta.
- Inicios de sesión desde ubicaciones o dispositivos no habituales.
- Transferencias repetitivas hacia destinatarios desconocidos.
- Generación masiva de cuentas con información similar.
- Uso de dispositivos modificados o con software no autorizado.

Ante cualquiera de estas situaciones, el usuario deberá suspender la operación y comunicarse con los canales oficiales de NexaLend.

FIN DEL DOCUMENTO

Política de Seguridad y Prevención de Fraudes – NexaLend – Versión 1.0